



Администратор Linux

Пользователи и группы
Авторизация и аутентификация



Проверить, идет ли запись

Меня хорошо видно && слышно?



Ставим "+", если все хорошо
"-", если есть проблемы



Правила вебинара



Активно
участвуем



Off-topic обсуждаем
в группе Telegram
OTUS-Linux-2022-02



Задаем вопрос
в чат или голосом



Вопросы вижу в чате,
могу ответить не сразу



Маршрут вебинара

Знакомство

Базовые понятия и ACL

Capabilities

Polkit

PAM

Рефлексия

Цели вебинара

К концу занятия вы сможете

1. Управлять правами доступа стандартными средствами Linux (chmod/chown)



-
2. Использовать capabilities и polkit



-
3. Ориентироваться в конфигурации PAM



Смысл

Зачем вам это уметь

1. Управление доступом и разграничение прав — стандартная задача для администратора
 2. Не всегда задачу можно решить базовыми средствами (`chmod/chown`)
-



Базовые понятия

Базовые понятия

- **Идентификация** – сопоставление идентификатора пользователя (UID) с символическим именем
- **Аутентификация** – процесс подтверждения, что пользователь является тем, за кого себя выдаёт
- **Авторизация** – подтверждение, что пользователь имеет доступ к ресурсу, к которому обращается
- **Аккаунтинг** – учёт и контроль, ведение записей входа/выхода

/etc/passwd

CentOS 7

```
$ cat /etc/passwd
root:x:0:0:root:/root:/bin/bash
bin:x:1:1:bin:/bin:/sbin/nologin
daemon:x:2:2:daemon:/sbin:/sbin/nologin
oracle:x:54321:54321::/home/oracle:/bin/bash
zabbix:x:54322:54323::/home/zabbix:/bin/bash
...
```

/etc/shadow

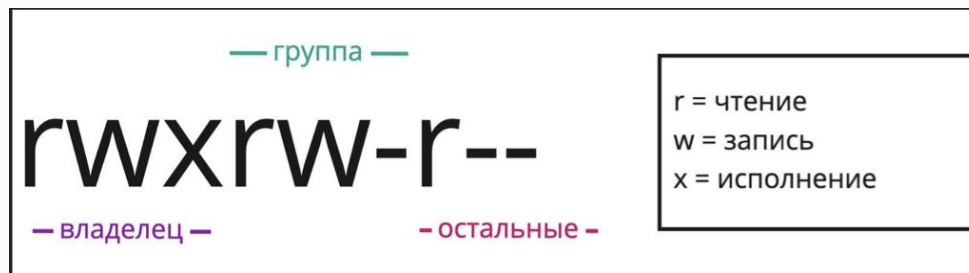
CentOS 7

```
$ cat /etc/shadow
root:!!$6$XcUsJ64F1xhLGjFO$AhCj3tGpXz6PYsxXdu2CwbMTHA5cQPnNd3IlqXw2BrXD243g4REkCU1Rn0JuTZIfOOav3ZLvR
HNJwVrFylgjk0::0:99999:7:::
bin:*:17768:0:99999:7:::
daemon:*:17768:0:99999:7:::
ivan:$6$/4MvTHj7$KLwxNEZ1QqwrK8eFlLxfXY7U2Eh0lnCAkgxecXCcy8bqjDY.e56mxMLpYt6LTV/1cmryP5qC.ErgVbtrmZW
9a/:19012:0:99999:7:::
...
```

Права доступа к файлам

CentOS 7

```
$ ls -l FILE  
-rw-r--r--. 1 root root 0 May  7 15:36 FILE
```



Числовая запись

0645

owner (владелец)	group (группа)	other (остальные)
rw-	r--	r-x
110	100	101
6	4	5

Специальные права доступа

7645

	owner (SUID)	group (GUID)	other (sticky)
	rwS	r-S	t-T
111	110	100	101
7	6	4	5



SUID, GUID, Sticky

- **SUID** – исполняемый файл запускается с правами владельца
- **GUID** – исполняемый файл запускается с правами группы
- **Sticky** – файлы в директории может удалять/переименовывать только владелец файла (или root)

**Как настроение?
Есть ли вопросы?**

ACL

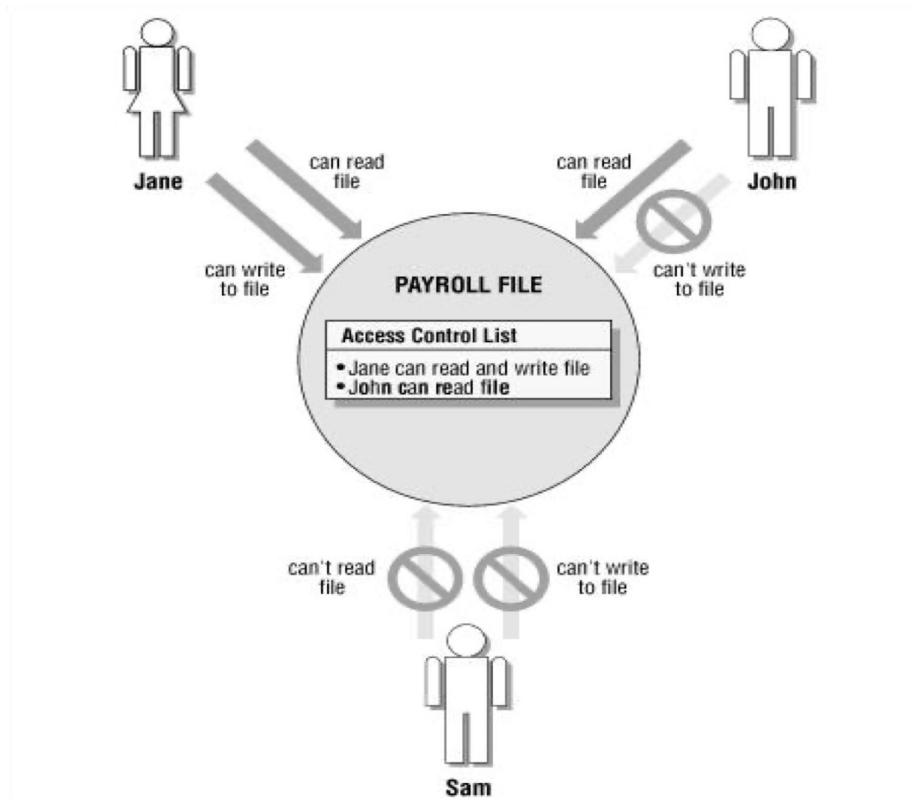
ACL (Access Control List)

ACL (Access Control List) — расширенные права доступа к файлам в Linux.

Особенности:

- Поддержка ACL на файловых системах ext4 и XFS включена по умолчанию
- Не все утилиты поддерживают ACL

ACL (Access Control List)



Пример настройки ACL

CentOS 7

```
$ setfacl -m u:zabbix:r FILE
$ getfacl FILE
# file: FILE
# owner: root
# group: root
user::rw-
user:zabbix:r--
group::r--
mask::r--
other::r--

$ setfacl -x u:zabbix FILE
$ getfacl FILE
# file: FILE
# owner: root
# group: root
user::rw-
group::r--
mask::r--
other::r--
```

Capabilities

Capabilities

Capabilities — это средства для управления привилегиями, которые в традиционных Unix-подобных системах были доступны только процессам, запущенным с правами root (`uid==0`).

Пример:

- **CAP_SYS_ADMIN** — Разрешить диапазон системных административных операций
- **CAP_SYS_BOOT** — Разрешить вызовы к `reboot`
- **CAP_SYS_CHROOT** — Разрешить вызовы к `chroot`

Capabilities (флаги для процесса)

- **Permitted** — требуется запрос на выполнение
- **Inheritable** — можно унаследовать потомкам
- **Effective** — какие действия может выполнить процесс
- **Bounding (ограничивающий набор)** — до Linux 2.6.25 был общесистемным атрибутом, общим для всех потоков, предназначенным для описания набора, за пределы которого разрешения расширяться не могут. В настоящее время это набор для каждой задачи и является лишь частью логики `execve`
- **Ambient (наружные, начиная с Linux 4.3)** — добавлены, чтобы легче предоставлять разрешения `не-root` пользователю, без использования `setuid` или файловых разрешений

Capabilities (флаги для файла)

- **Permitted** — разрешенный набор для файла
- **Inheritable** — список свойств, которые можно унаследовать от парента
- **Effective** — бит разрешения для permitted set

Capabilities (просмотр и расшифровка)

CentOS 7

```
$ cat /proc/self/status | grep Cap
CapInh: 0000000000000000
CapPrm: 0000000000000000
CapEff: 0000000000000000
CapBnd: 0000003fffffffff
CapAmb: 0000000000000000
```

```
$ capsh --decode=0000003fffffffff
```

```
0x0000003fffffffff=cap_chown,cap_dac_override,cap_dac_read_search,cap_fowner,cap_fsetid,cap_kill,cap_setgid,cap_setuid,cap_setpcap,cap_linux_immutable,cap_net_bind_service,cap_net_broadcast,cap_net_admin,cap_net_raw,cap_ipc_lock,cap_ipc_owner,cap_sys_module,cap_sys_rawio,cap_sys_chroot,cap_sys_ptrace,cap_sys_pacct,cap_sys_admin,cap_sys_boot,cap_sys_nice,cap_sys_resource,cap_sys_time,cap_sys_tty_config,cap_mknod,cap_lease,cap_audit_write,cap_audit_control,cap_setfcap,cap_mac_override,cap_mac_admin,cap_syslog,35,36,37
```

Capabilities (утилиты)

CentOS 7

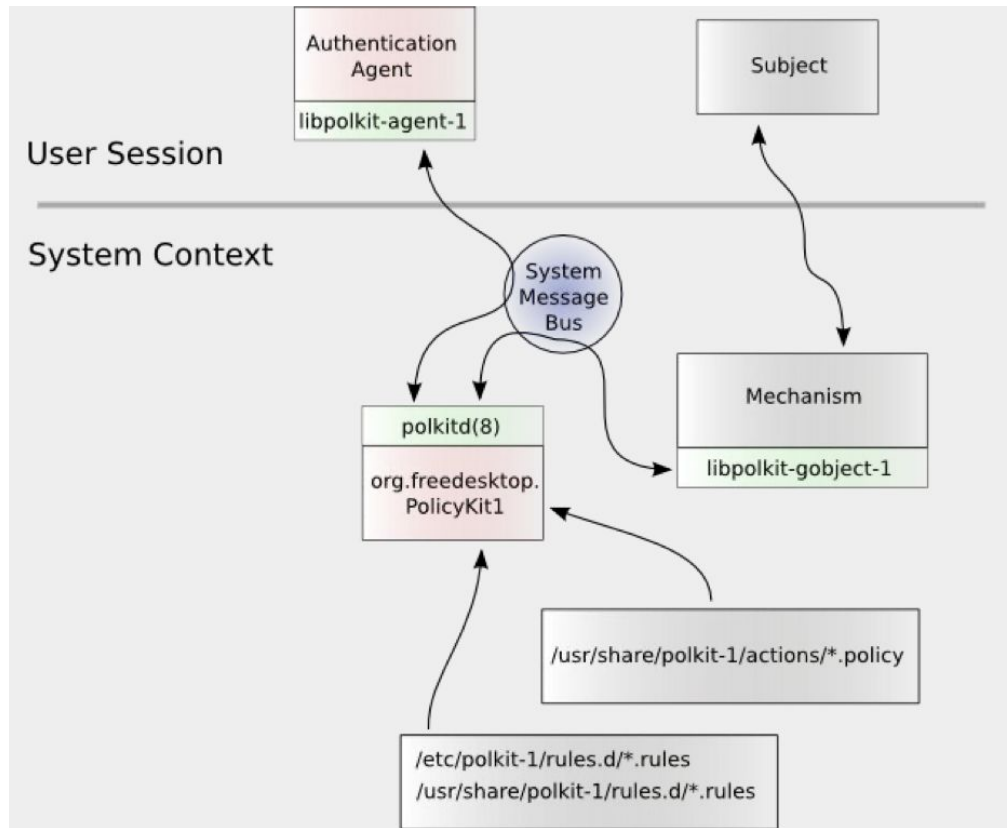
```
# setcap
# устанавливает и удаляет capabilities на исполняемый файл
# man 7 capabilities
$ setcap cap_net_admin,cap_net_raw+eip /usr/sbin/tcpdump
$ setcap -r /usr/bin/ping cap_net_raw

# getcap/getpcaps
# узнать установленные capabilities
$ getcap /usr/sbin/tcpdump
$ getpcaps <pid>

$ setcap cap_net_bind_service=+ep /usr/bin/ncat
$ getcap /usr/bin/ncat
```

Polkit

Polkit



Polkit

- **pkaction** — служит для просмотра возможных действий, которые отслеживает PolicyKit.
- **pkcheck** — позволяет проверить, авторизовался ли процесс для выполнения действия.
- **pkexec** — позволяет пользователю выполнить действие или программу от имени другого пользователя.
- **pktttyagent** — позволяет выполнить текстовую авторизацию таким приложениям, которые запускаются без пользовательского графического окружения, например, ssh.

Polkit (пример 1)

CentOS 7

```
# Включаем логирование
$ vim /etc/polkit-1/rules.d/00-access.rules
polkit.addRule(function(action, subject) {
    polkit.log("action=" + action);
    polkit.log("subject=" + subject);
});
```



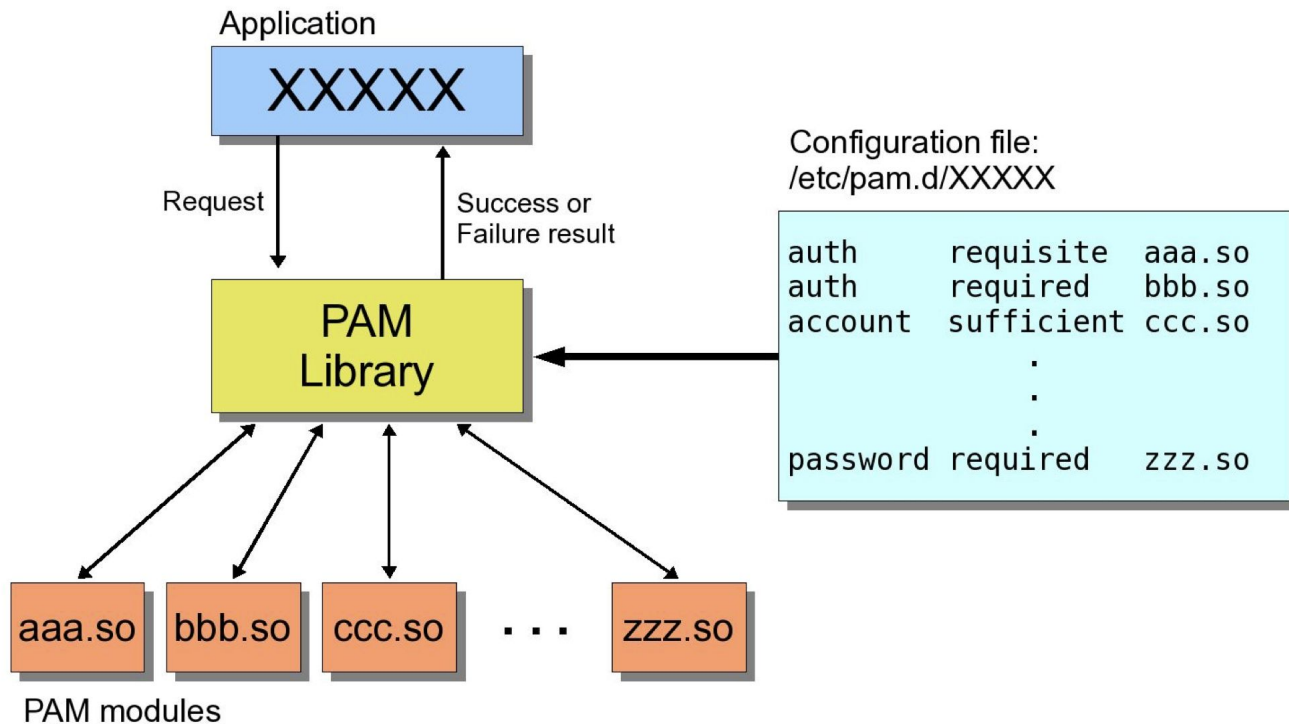
Polkit (пример 2)

CentOS 7

```
# Право на запуск сервисов systemd
$ vim /etc/polkit-1/rules.d/01-systemd.rules
polkit.addRule(function(action, subject) {
    if
    (action.id.match("org.freedesktop.systemd1.ma
nage-units") && subject.user === "ivan") {
        return polkit.Result.YES;
    }
});
```

PAM

PAM (Pluggable Authentication Modules)



РАМ (конфигурация)

Конфигурация для каждого сервиса определяется в формате:

type control module-path module-arguments

В конфигурации, внутри каждого стека (type) есть один или несколько модулей, которые просматриваются по порядку (сверху-вниз) и, в зависимости от control-a(sufficient, required) проверка либо продолжается, либо прекращается.

РАМ (типы модулей)

1. **Модуль аутентификации** используется для аутентификации пользователей или создании и удалении учетных данных.
2. **Модуль управления учетными записями** выполняет действия, связанные с доступом, истечением учетных данных или записей, правилами и ограничениями для паролей и т. д.
3. **Модуль управления сеансами** используется для создания и завершения сеансов.
4. **Модуль управления паролями** выполняет действия, связанные с изменением и обновлением пароля.

PAM (control)

- **required** — для успешного завершения проверки этот модуль должен сработать, проверка продолжается вне зависимости от результата;
- **requisite** — как required, только при ошибке проверка прекращается. Возвращается ошибка первого required/requisite модуля вернувшего ошибку;
- **sufficient** — при успехе возвращается ОК и проверка завершается;
- **optional** — опциональный модуль. Успех или Ошибка важны только в случае если это единственный модуль в стеке;
- **include** — включить в текущий стек модулей стек модулей из файла;
- **substack** — включить в текущий стек результат модулей из файла.

РАМ (пример)

С помощью пакета `pam_script` можно быстро и гибко расширять AAA-процесс и использовать возможности РАМ.

- **pam_succeed_if** — разрешает вход только заданным группам
auth required pam_succeed_if.so gid=1000,2000
- **pam_deny** — все запретить
- **pam_unix** — проверка пароля через shadow
- **pam_mysql** — проверка пользователя через mysql
- **pam_cracklib** — установка политик пароля
- **pam_rootok** — разрешение руту обходить доп проверки
- **pam_limits** — установка лимитов для пользователей

Вопросы?



Ставим “+”,
если вопросы есть



Ставим “-”,
если вопросов нет

Рефлексия

Вопросы для проверки

В контексте концепции AAA, какой процесс отвечает за запись информации о произошедших событиях?

- A. Аутентификация (Authentication)
- B. Авторизация (Authorization)
- C. Учёт (Accounting)
- D. Идентификация (Identification)



Отправьте в чат верную букву

Вопросы для проверки

В контексте концепции AAA, какой процесс отвечает за запись информации о произошедших событиях?

- A. Аутентификация (Authentication)
- B. Авторизация (Authorization)
- C. Учёт (Accounting)**
- D. Идентификация (Identification)

Вопросы для проверки

Классический способ блокировки учетной записи пользователя, при котором пароль делается непроверяемым, достигается путем:

- A. Установки expiry date в будущем.
- B. Установки shell в /bin/bash.
- C. Блокировки пароля (добавления символа "!").
- D. Удаления имени пользователя из /etc/login.defs.



Отправьте в чат верную букву

Вопросы для проверки

Классический способ блокировки учетной записи пользователя, при котором пароль делается непроверяемым, достигается путем:

- A. Установки expiry date в будущем.
- B. Установки shell в /bin/bash.
- C. Блокировки пароля (добавления символа "!").**
- D. Удаления имени пользователя из /etc/login.defs.

Вопросы для проверки

Где по умолчанию конфигурируются модули PAM (Pluggable Authentication Modules) для каждого отдельного сервиса (демона)?

- A. Внутри системного вызова `execve`.
- B. В файле `/etc/pam.conf`.
- C. В директории `/etc/shells`.
- D. В директории `/etc/pam.d` (имя файла совпадает с именем демона).



Отправьте в чат верную букву

Вопросы для проверки

Где по умолчанию конфигурируются модули PAM (Pluggable Authentication Modules) для каждого отдельного сервиса (демона)?

A. Внутри системного вызова `execve`.

B. В файле `/etc/pam.conf`.

C. В директории `/etc/shells`.

D. В директории `/etc/pam.d` (имя файла совпадает с именем демона).

Вопросы для проверки

В конфигурации РАМ, какой контрольный флаг (control) требует, чтобы модуль успешно сработал, и при ошибке немедленно прекращает всю дальнейшую проверку стека?

- A. required
- B. sufficient
- C. requisite
- D. optional



Отправьте в чат верную букву

Вопросы для проверки

В конфигурации PAM, какой контрольный флаг (control) требует, чтобы модуль успешно сработал, и при ошибке немедленно прекращает всю дальнейшую проверку стека?

- A. required
- B. sufficient
- C. requisite**
- D. optional

Цели вебинара

К концу занятия вы сможете

1. Управлять правами доступа стандартными средствами Linux (chmod/chown)



-
2. Использовать capabilities и polkit



-
3. Ориентироваться в конфигурации PAM



Рефлексия



С какими впечатлениями уходите с вебинара?



Как будете применять на практике то, что узнали на вебинаре?

**Заполните, пожалуйста,
опрос о занятии
по ссылке в чате**